

Federated Digital Twin Catalogs

A split-trust architecture
for secure data
publication

Fernando Latorre, Ivan Becerro, Nuria Sala
April 11, 2026

Separate risk in a split-trust architecture

Level 0: EHR

- Level 0: Real patient data (Electronic Health Records or EHR)

Level 1: local service

- Level 1: Separate local digital twins (pseudonymization)

Level 2: aggregator

- Level 2: Federated digital twins (aggregation and pseudonymization)

Level 3: public search

- Level 3: Catalog and governed discovery layer



First protection step

The Electronic Health Records (EHR) stores the real patient identity and internal identifier.

Level 0

Real patient data + internal ID.
Example: local EHR number.
This lives inside the clinical system.

Why this is sensitive

Anyone who gets that value
could more easily connect
records, systems, or personal
data.

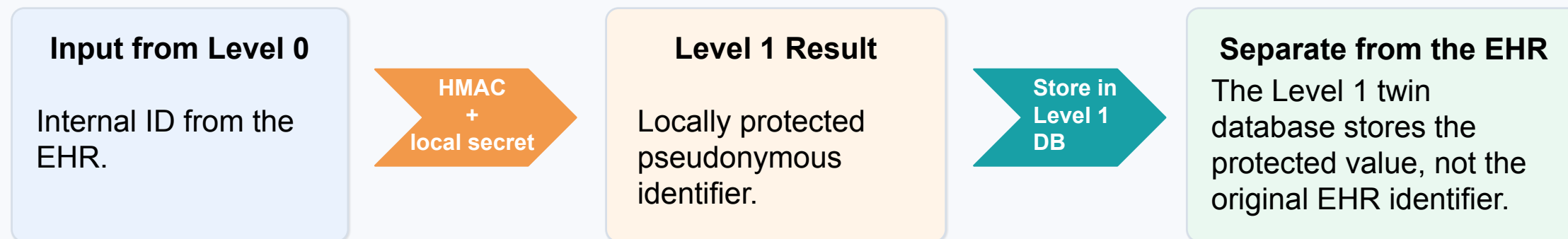
Architectural goal

Keep the real identity inside
the EHR and protect it
before any federated use.

The first protection step is performed by a separate local pseudonymization service, controlled by the organization, before any identifier reaches the federated layer.

Level 1: local pseudonymization service

A separate local service controlled by the organization's IT team applies HMAC or another keyed one-way function using a local secret.



Free text is removed and only coded clinical data are kept for the digital twin dataset. Level 1 is functionally separate from the EHR. It creates the first protection boundary.

Hash-based Message Authentication Code (HMAC)

It is a cryptographic method that combines a hash function (e.g., SHA-256) with a secret key.

What HMAC does:

- It uses a secret key and an input.
- It produces a protected output.
- The service that holds the secret key can verify whether a given identifier corresponds to a stored protected twin identifier by recomputing the HMAC output with the same key.

Verification with the key

What HMAC does not do:

- It is not encryption.
- It is not something you “decrypt”.
- The output hides the original identifier. It cannot be directly reversed.

Not decryption

First Security Layer

If Level 1 is breached, the attacker still cannot directly recover the real identifier from the digital twins database.

Attacker sees

Local pseudonyms not the original internal IDs

What is still missing

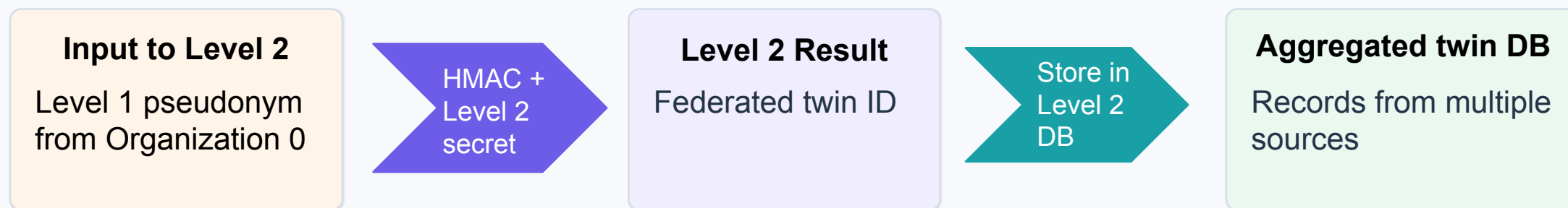
The attacker would still need the Level 1 local secret key to test or recompute identifiers.

Even then...

At most, the attacker moves toward the organization's internal identifier. That is still not the patient's name or personal details.

Second Security Layer

An attacker would need both the Level 2 secret and the Level 1 secret to move backward.



Level 2 adds a second protection layer across organizations.
The Level 1 pseudonym is transformed again with a different secret in the aggregation domain.
Only coded clinical data are aggregated, not raw free text.

One breach is not enough

To attack Level 2 data

Need the Level 2 key
+ access to aggregated
records

To move toward Level 1

Need the Level 1 key
from the original
organization.

To identify the person

Need access to the
original local systems
that relate internal IDs
to real patients.

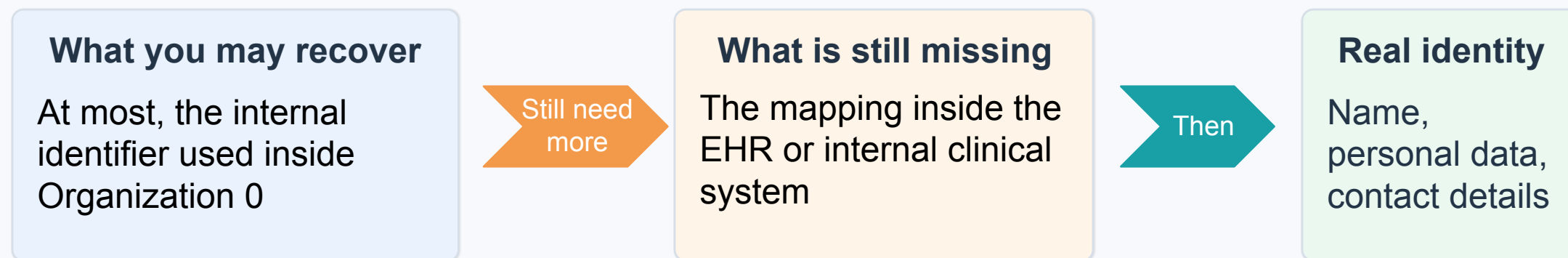
Result

An attacker would
need multiple
independent
compromises, not
just one stolen
database.

The split-trust design turns a single-point exposure risk into a multi-domain compromise problem.

Even after both HMAC layers

Recovering an internal identifier is still not the same as reaching the real person in Level 0.



The real-world identity remains separated from the federated identifier by additional operational barriers.

Governance is still needed for indirect disclosure risk

Level 1 + Level 2

Protect direct identifiers through split-trust pseudonymization.

Level 3 publication

Publishes aggregated datasets or metadata for discovery under governance controls.

Governance examples

- Minimum cohort sizes
- Aggregation windows
- Audit rules
- Controlled access policies

Level 3 is less central to core identifier security.
Governance helps reduce indirect re-identification risk from small cohorts, rare diseases, and highly specific data combination.

Conclusion

At Level 1, the internal identifiers are protected with a keyed one-way function.

At Level 2, the aggregator protects that pseudonym again with a different secret.

A breach of one database is not enough:

Re-identification would require compromise of multiple independent systems, multiple secret keys, and the original clinical environment.

Level 0: Local Patient ID



Level 1: Local twin



Level 2: Federated twin